

Security & Threat Model

ServiceGuard AI

1. Trust boundaries

```
User
↓ HTTPS
Frontend
↓ HTTPS
Spring Boot
■■■ PostgreSQL
■■■ Redis
■■■ Python AI service
■■■ LLM
■■■ vector store
■■■ external APIs
```

2. Threats

Threat	Control
Prompt injection via runbook/document	Treat retrieved content as untrusted data; isolate instructions from evidence
LLM overreach	Tool allowlist + structured outputs + approval
Unauthorized data access	RBAC + semantic views + service identities
Secret leakage	Environment/secrets manager; never include secrets in prompts
SQL injection	Parameterized queries/JPA; no raw LLM SQL
AI service compromise	Internal network + authentication + minimal permissions
Audit tampering	Restricted audit writes and controlled admin access
DoS / expensive AI calls	Redis rate limiting + quotas + bounded tool calls

3. Roles

- DISPATCHER: operational read + AI + incident review.
- MANAGER: dispatcher capabilities + approval/escalation.
- ADMIN: configuration/user/audit administration.

4. Database roles

- Application role with only required CRUD permissions.
- AI read role restricted to semantic views.
- Separate migration/admin role.
- Audit writes exposed through controlled backend operations.

5. AI security principle

The model never receives database credentials and never receives unrestricted access to the operational database.